

HARDENING REPORT

Projet: `audit-platform`

Date: 2026-05-13

Type d'audit: audit structurel statique du depot Laravel, avec focus sur les phases 1.5 et 2.

Limite importante: ce rapport est base sur l'analyse du code, des migrations, des modeles, des controllers, des polices et des vues. La CLI `php` n'etait pas disponible dans l'environnement d'audit, donc l'execution des tests, de `artisan migrate:status` et la verification de la table runtime `migrations` n'ont pas pu etre confirmees directement.

1. Inventaire base de donnees

1.1 Inventaire des tables, colonnes, soft deletes, statuts et JSON

Format:

? `Table`

- Colonnes: ...
- Soft deletes: present / absent
- Colonnes `status/state/active`: ...
- JSON / metadata: ...

? `actifs`

- Colonnes: `id`, `processus\_id`, `nom`, `description`, `type`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `actions\_correctives`

- Colonnes: `id`, `risque\_id`, `description`, `responsable`, `date\_echeance`, `statut`, `recommendation\_library\_id`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: `statut`
- JSON / metadata: aucun

? `audit\_logs`

- Colonnes: `id`, `user\_id`, `action`, `module`, `description`, `ip`, `user\_agent`, `metadata`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: `metadata`

? `audit\_plans`

- Colonnes: `id`, `mission\_id`, `titre`, `description`, `niveau`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `audit\_programmes`

- Colonnes: `id`, `audit\_plan\_id`, `procedure`, `type`, `created\_at`, `updated\_at`

- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `cache`

- Colonnes: `key`, `value`, `expiration`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `cache\_locks`

- Colonnes: `key`, `owner`, `expiration`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `constats`

- Colonnes: `id`, `mission\_id`, `service\_id`, `description`, `cause`, `consequence`, `recommandation`, `gravite`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `controles`

- Colonnes: `id`, `risque\_id`, `description`, `type`, `efficacite`, `commentaire`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `department\_audit consolidations`

- Colonnes: `id`, `mission\_id`, `department\_id`, `synthesis`, `global\_risk\_level`, `key\_findings`, `recommendations`, `generated\_by\_ai`, `validated\_by`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `departments`

- Colonnes: `id`, `name`, `code`, `type`, `description`, `active`, `accent\_color`, `logo\_path`, `supervisor\_user\_id`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: `active`
- JSON / metadata: aucun

? `entretien\_responses`

- Colonnes: `id`, `entretien\_id`, `questionnaire\_question\_id`, `answer\_boolean`, `answer\_text`, `answer\_json`, `observation`, `uploaded\_documents\_metadata`, `detected\_risk`, `created\_by`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: `answer\_json`, `uploaded\_documents\_metadata`

? `entretiens`

- Colonnes: `id`, `mission\_id`, `service\_id`, `responsable\_nom`, `role`, `chef\_hierarchique`, `auditeur`, `date\_entretien`, `email`, `telephone`, `notes`, `questionnaire\_template\_id`, `conducted\_by`, `interviewed\_person`, `interviewed\_role`, `conducted\_at`, `status`, `validation\_status`, `synthesis`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: `status`, `validation\_status`
- JSON / metadata: aucun

? `failed\_jobs`

- Colonnes: `id`, `uuid`, `connection`, `queue`, `payload`, `exception`, `failed\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `identified\_risks`

- Colonnes: `id`, `mission\_id`, `service\_id`, `entretien\_id`, `questionnaire\_question\_id`, `title`, `description`, `category`, `probability`, `impact`, `criticality`, `recommendation`, `ai\_generated`, `validated\_by\_human`, `created\_by`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `job\_batches`

- Colonnes: `id`, `name`, `total\_jobs`, `pending\_jobs`, `failed\_jobs`, `failed\_job\_ids`, `options`, `cancelled\_at`, `created\_at`, `finished\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `jobs`

- Colonnes: `id`, `queue`, `payload`, `attempts`, `reserved\_at`, `available\_at`, `created\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `mission\_documents`

- Colonnes: `id`, `mission\_id`, `service\_id`, `entretien\_id`, `uploaded\_by`, `filename`, `original\_name`, `mime\_type`, `disk`, `path`, `size`, `category`, `description`, `version`, `metadata`, `created\_at`, `updated\_at`, `deleted\_at`
- Soft deletes: present
- Colonnes `status/state/active`: aucune
- JSON / metadata: `metadata`

? `mission\_raci\_previews`

- Colonnes: `id`, `mission\_id`, `service\_id`, `process\_label`, `status`, `metadata`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: `status`
- JSON / metadata: `metadata`

? `mission\_swot\_previews`

- Colonnes: `id`, `mission\_id`, `service\_id`, `status`, `metadata`, `created\_at`, `updated\_at`
- Soft deletes: absent

- Colonnes `status/state/active`: `status`

- JSON / metadata: `metadata`

? `mission\_team\_members`

- Colonnes: `id`, `mission\_id`, `user\_id`, `mission\_role`, `designation`, `is\_lead`,
`assigned\_by`, `assigned\_at`, `created\_at`, `updated\_at`

- Soft deletes: absent

- Colonnes `status/state/active`: aucune

- JSON / metadata: aucun

? `mission\_workflow\_events`

- Colonnes: `id`, `mission\_id`, `user\_id`, `action`, `from\_status`, `to\_status`, `comment`,
`created\_at`, `updated\_at`

- Soft deletes: absent

- Colonnes `status/state/active`: `from\_status`, `to\_status`

- JSON / metadata: aucun

? `missions`

- Colonnes: `id`, `organisation`, `reference`, `objet`, `description`, `periode\_audit`,
`ordre\_mission\_reference`, `date\_ordre\_mission`, `observations\_generales`, `date\_debut`,
`date\_fin`, `deadline`, `auditeur\_id`, `department\_id`, `mission\_type`, `mission\_status`,
`priority`, `sensitivity\_level`, `confidentiality\_level`, `supervising\_department\_id`,
`created\_at`, `updated\_at`

- Soft deletes: absent

- Colonnes `status/state/active`: `mission\_status`

- JSON / metadata: aucun

? `notifications`

- Colonnes: `id`, `type`, `notifiable\_type`, `notifiable\_id`, `data`, `read\_at`, `created\_at`,
`updated\_at`

- Soft deletes: absent

- Colonnes `status/state/active`: aucune

- JSON / metadata: aucun

? `password\_reset\_tokens`

- Colonnes: `email`, `token`, `created\_at`

- Soft deletes: absent

- Colonnes `status/state/active`: aucune

- JSON / metadata: aucun

? `permission\_role`

- Colonnes: `id`, `role\_id`, `permission\_id`

- Soft deletes: absent

- Colonnes `status/state/active`: aucune

- JSON / metadata: aucun

? `permissions`

- Colonnes: `id`, `slug`, `name`, `group`, `created\_at`, `updated\_at`

- Soft deletes: absent

- Colonnes `status/state/active`: aucune

- JSON / metadata: aucun

? `personal\_access\_tokens`

- Colonnes: `id`, `tokenable\_type`, `tokenable\_id`, `name`, `token`, `abilities`, `last\_used\_at`,
`expires\_at`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `processus`

- Colonnes: `id`, `mission\_id`, `nom`, `description`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `questionnaire\_questions`

- Colonnes: `id`, `questionnaire\_section\_id`, `code`, `question`, `help\_text`, `question\_type`,
`required`, `allows\_observation`, `allows\_risk\_detection`, `expected\_documents`, `risk\_category`,
`risk\_level`, `sort\_order`, `active`, `metadata`, `created\_at`, `updated\_at`, `deleted\_at`
- Soft deletes: present
- Colonnes `status/state/active`: `active`
- JSON / metadata: `metadata`

? `questionnaire\_sections`

- Colonnes: `id`, `questionnaire\_template\_id`, `title`, `description`, `sort\_order`, `created\_at`,
`updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `questionnaire\_templates`

- Colonnes: `id`, `name`, `slug`, `description`, `mission\_type`, `department\_scope`, `active`,
`version`, `created\_by`, `updated\_by`, `created\_at`, `updated\_at`, `deleted\_at`
- Soft deletes: present
- Colonnes `status/state/active`: `active`
- JSON / metadata: `department\_scope`

? `questionnaires`

- Colonnes: `id`, `entretien\_id`, `titre`, `description`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `questions`

- Colonnes: `id`, `questionnaire\_id`, `question`, `type`, `probabilite`, `impact`, `created\_at`,
`updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `recommendation\_libraries`

- Colonnes: `id`, `titre`, `description`, `categorie`, `type\_controle`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `reponses`

- Colonnes: `id`, `entretien\_id`, `question\_id`, `reponse`, `commentaire`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `risk\_libraries`

- Colonnes: `id`, `titre`, `description`, `processus`, `categorie`, `probabilite\_default`, `impact\_default`, `risk\_library\_id`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `risques`

- Colonnes: `id`, `actif\_id`, `description`, `niveau`, `proprietaire`, `departement`, `date\_revue`, `plan\_mitigation`, `statut\_risque`, `impact\_inherent`, `probabilite\_inherent`, `criticite\_inherent`, `score\_inherent`, `impact\_residuel`, `probabilite\_residuel`, `criticite\_residuel`, `score\_residuel`, `severity`, `owner\_department\_id`, `source\_department\_id`, `target\_department\_id`, `shared`, `cross\_department`, `escalated`, `treatment\_plan`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: `statut\_risque`
- JSON / metadata: aucun

? `roles`

- Colonnes: `id`, `slug`, `name`, `description`, `hierarchy\_level`, `active`, `created\_at`, `updated\_at`
- Soft deletes: absent
- Colonnes `status/state/active`: `active`
- JSON / metadata: aucun

? `services`

- Colonnes: `id`, `mission\_id`, `code`, `nom`, `responsable`, `description`, `chef\_service\_user\_id`, `chef\_service\_nom`, `chef\_service\_fonction`, `chef\_service\_email`, `chef\_service\_telephone`, `service\_type`, `service\_scope`, `active`, `observations`, `audit\_priority`, `risk\_level`, `audit\_status`, `metadata`, `created\_at`, `updated\_at`, `deleted\_at`
- Soft deletes: present
- Colonnes `status/state/active`: `active`, `audit\_status`
- JSON / metadata: `metadata`

? `sessions`

- Colonnes: `id`, `user\_id`, `ip\_address`, `user\_agent`, `payload`, `last\_activity`
- Soft deletes: absent
- Colonnes `status/state/active`: aucune
- JSON / metadata: aucun

? `users`

- Colonnes: `id`, `name`, `prenom`, `email`, `email\_verified\_at`, `password`, `remember\_token`, `role`, `department\_id`, `role\_id`, `active`, `position`, `telephone`, `phone`, `matricule`, `date\_naissance`, `fonction`, `last\_login\_at`, `failed\_login\_attempts`, `locked\_until`,

`mfa\_enabled`, `mfa\_recovery\_codes`, `profile\_photo`, `approval\_status`, `approved\_at`,
`approved\_by`, `registration\_requested\_department\_id`, `password\_changed\_at`,
`must\_change\_password`, `password\_expires\_at`, `deleted\_at`, `deleted\_by`, `created\_at`,
`updated\_at`

- Soft deletes: present
- Colonnes `status/state/active`: `active`, `approval\_status`
- JSON / metadata: aucun

1.2 Tables manquantes referencees dans le code

CRITICAL

? `mission\_services` est implicitement referencee par Eloquent via
`App\Models\MissionService`, parce que ce modele n'ecrase pas `\$table`. Par convention,
Eloquent visera `mission\_services`, alors que seule la table `services` existe.

MINOR

? Aucune autre table explicitement referencee via `DB::table(...)`, `protected \$table`,
`exists:` ou relations n'apparait manquante dans les migrations.

1.3 Colonnes referencees mais inexistantes

MAJOR

? `reponses.observation` est referencee par `App\Models\Reponse`, alors que la colonne
migree est `commentaire`.

MINOR

? Le pivot `permission\_role` est utilise avec `withTimestamps()` dans
`App\Models\Permission`, mais la table ne contient pas `created\_at` / `updated\_at`.

1.4 Observations base de donnees

? La plateforme contient simultanement un ancien systeme de questionnaires
(`questionnaires`, `questions`, `reponses`) et un nouveau systeme
(`questionnaire\_templates`, `questionnaire\_sections`, `questionnaire\_questions`,
`entretien\_responses`). Ce double systeme est acceptable en transition, mais augmente
fortement le risque de derive fonctionnelle.

2. Audit des modeles Eloquent

2.1 Resume global

? Nombre de modeles trouves dans `app/Models`: 31
? Modeles avec `SoftDeletes` coherents avec le schema:

- `User`
- `Service`
- `MissionDocument`
- `QuestionnaireTemplate`
- `QuestionnaireQuestion`

? Modeles a risque structurel fort:

- `MissionService`
- `Mission`
- `Reponse`

- `QuestionnaireSection`

2.2 Audit modele par modele

? `ActionCorrective`

- Table reelle: oui (`actions\_correctives`)
- Relations: plausibles
- Casts: incomplets (`date\_echeance` non caste)
- SoftDeletes: absent / coherent
- Fillable: non audite en detail ici
- Niveau: MINOR

? `Actif`

- Table reelle: oui (`actifs`)
- Relations: plausibles
- SoftDeletes: absent / coherent
- Policy dediee: absente
- Niveau: MAJOR (gouvernance d'ecriture, pas schema)

? `AuditLog`

- Table reelle: oui (`audit\_logs`)
- Relations: plausibles
- Policy dediee: non necessaire si acces gere par gate admin
- Niveau: OK structurel

? `Constat`

- Table reelle: oui (`constats`)
- Relations: non verifiees exhaustivement
- Niveau: MINOR

? `Controle`

- Table reelle: oui (`controles`)
- Relations: plausibles
- Policy dediee: absente
- Niveau: MAJOR

? `Department`

- Table reelle: oui (`departments`)
- Policy: presente et enregistree
- Niveau: OK structurel

? `DepartmentAuditConsolidation`

- Table reelle: oui
- Relations: coherentes
- Casts: `generated\_by\_ai` coherent
- Policy: presente et enregistree
- Niveau: OK structurel

? `Entretien`

- Table reelle: oui
- Relations: globalement coherentes
- Casts: `conducted\_at`, `date\_entretien` cohérents
- SoftDeletes: absent / coherent
- Fillable: large mais coherent avec le schema

- Risque: `questionnaireCompletionPercent()` compte toutes les reponses, y compris celles de questions potentiellement inactives

- Niveau: MINOR

? `EntretienResponse`

- Table réelle: oui

- Relations: cohérentes

- Casts: `answer\_json`, `uploaded\_documents\_metadata` cohérents

- Policy dédiée: absente, mais l'accès est actuellement médié par `EntretienPolicy`

- Niveau: MINOR

? `IdentifiedRisk`

- Table réelle: oui

- Relations: cohérentes

- Policy: présente et enregistrée

- Niveau: OK structurel

? `Mission`

- Table réelle: oui

- Relations: majoritairement cohérentes

- Casts: dates cohérentes

- SoftDeletes: absent / cohérent

- Problème critique: relation `auditPlans()` vers `AuditPlan::class` sans modèle présent, et méthode `genererPlanAuditAutomatique()` appelle aussi `AuditProgramme::create()` sans modèle présent

- Default applicatif `mission\_status = brouillon`, mais default DB encore dérivé de `draft`

- Niveau: CRITICAL

? `MissionDocument`

- Table réelle: oui

- Relations: cohérentes

- Casts: cohérents

- SoftDeletes: présent / cohérent

- Policy: présente et enregistrée

- Niveau: OK structurel

? `MissionRaciPreview`

- Table réelle: oui

- Relations: cohérentes

- Policy dédiée: absente, acceptable tant qu'aucune route d'écriture n'est exposée

- Niveau: MINOR

? `MissionService`

- Table réelle: non, car le modèle n'écrit pas `\$table` vers `services`

- Relations: héritées de `Service`

- SoftDeletes: héritées via `Service`

- Problème critique: Eloquent résolvra `mission\_services`, table inexistante

- Problème critique additionnel: incohérence avec le route binding qui retourne un `Service`

- Niveau: CRITICAL

? `MissionSwotPreview`

- Table réelle: oui

- Relations: cohérentes

- Policy dediee: absente, acceptable tant qu'aucune route d'écriture n'est exposee

- Niveau: MINOR

? `MissionTeamMember`

- Table reelle: oui

- Relations: plausibles

- Policy dediee: absente, acces actuellement porte par `MissionPolicy`

- Niveau: MINOR

? `MissionWorkflowEvent`

- Table reelle: oui

- Relations: plausibles

- Policy dediee: absente, acceptable si lecture toujours via mission

- Niveau: MINOR

? `Permission`

- Table reelle: oui

- Relations: pivot incoherent avec `withTimestamps()`

- Niveau: MAJOR

? `Processus`

- Table reelle: oui

- Relations: plausibles

- Policy dediee: absente

- Niveau: MAJOR

? `Question`

- Table reelle: oui (`questions`)

- Legacy model

- Niveau: MINOR

? `Questionnaire`

- Table reelle: oui (`questionnaires`)

- Legacy model incomplet par rapport au schema (`entretien\_id`, `description` sous-modele)

- Niveau: MINOR

? `QuestionnaireQuestion`

- Table reelle: oui

- Relations: coherentes

- Casts: coherents

- SoftDeletes: presents

- Risque: l'archivage est contredit par la suppression dure des sections parentes

- Niveau: MAJOR

? `QuestionnaireSection`

- Table reelle: oui

- Relations: coherentes

- SoftDeletes: absents

- Risque: suppression dure alors que les questions enfants sont soft deletables et peuvent deja etre referencees par `entretien\_responses`

- Niveau: MAJOR

? `QuestionnaireTemplate`

- Table reelle: oui

- Relations: coherentes
- Casts: coherents
- SoftDeletes: presents
- Probleme fonctionnel fort: policy completement ouverte
- Niveau: CRITICAL

? `RecommendationLibrary`

- Table reelle: oui
- Niveau: MINOR

? `Reponse`

- Table reelle: oui (`reponses`)
- Fillable incoherent (`observation` au lieu de `commentaire`)
- Niveau: MAJOR

? `Risque`

- Table reelle: oui
- Policy: presente et enregistree
- Risque majeur: creation API mal protegee
- Niveau: MAJOR

? `RiskLibrary`

- Table reelle: oui
- Niveau: MINOR

? `Role`

- Table reelle: oui
- Niveau: OK structurel

? `Service`

- Table reelle: oui
- Relations: coherentes
- Casts: coherents
- SoftDeletes: presents
- Risque majeur: `chef\_service\_user\_id` trop permissif dans les Form Requests
- Niveau: MAJOR

? `User`

- Table reelle: oui
- Relations / casts / soft deletes: globalement coherents
- Niveau: OK structurel, mais schema `users` souffre de migrations en double

2.3 Accessors / mutators

? `Service::responsibleDisplay()` est coherent, mais ne couvre pas le cas ou `chef\_service\_user\_id` est renseigne sans relation chargee.

? `Entretien::questionnaireCompletionPercent()` peut surevaluer la progression si des reponses subsistent pour des questions desactivees ou archivees.

3. Audit des controllers

3.1 Requetes sur colonnes inexistantes

? Aucune requete critique sur colonne inexistante n'a ete confirmee dans les controllers phases 1.5 et 2.

? Les principaux ecartes detectes portent plutot sur:

- mismatch modele / table
- mismatch policy / metier
- duplication fonctionnelle
- route binding incoherent

3.2 Findings controllers

CRITICAL

? `ServiceController` utilise `MissionService::query()` alors que `MissionService` pointe implicitement vers la table inexistante `mission\_services`.

? `MissionDocumentController` type-hint `MissionService \$service`, alors que `AppServiceProvider` bind le parametre `service` avec `Service::query()`. Le binding retourne donc un `Service`, pas un `MissionService`.

? `Api\V1\RiskController::store()` cree un `Risque` a partir de n'importe quel `actif\_id` valide, sans verifier la visibilite metier du parent. `StoreRisqueRequest::authorize()` accepte tout utilisateur authentifie.

MAJOR

? `EntretienConduiteController::storeResponses()` fait `updateOrCreate()` sur `EntretienResponse`, mais fait toujours `IdentifiedRisk::create()` pour le bloc `identified\_risk`. Une sauvegarde progressive produit donc des doublons de risques.

? `DashboardController` affiche une "Repartition des risques par service" calculee uniquement sur `mission\_id`. Toutes les lignes d'un meme service de mission peuvent donc recevoir le meme total.

? `QuestionnaireTemplateController::destroySection()` supprime durement la section, alors que des `entretien\_responses` peuvent deja référencer des questions enfants via une FK `restrictOnDelete`.

MINOR

? `MissionController` ajoute des KPI utiles, mais leur robustesse depend de la coherence des statuts `Entretien`.

? Les controllers legacy (`ProcessusController`, `ActifController`, `ControleController`, `ActionCorrectiveController`) reposent surtout sur la visibilite parent, sans policy dediee par ressource.

3.3 Eager loading invalides ou fragiles

CRITICAL

? `ServiceController` eager-load `entretiens.questionnaireTemplate.sections.questions` via `MissionService::query()`. Si `MissionService` ne pointe pas vers `services`, toute la chaine casse avant l'eager loading.

MINOR

? Aucun eager load manifestement indefini n'a ete confirme ailleurs dans les controllers phases 1.5 / 2.

3.4 Dependances circulaires / fortes

? Pas de dependance circulaire PHP explicite confirmee.

? Dependances fortes a surveiller:

- `Mission` -> `genererPlanAuditAutomatique()` -> classes absentes `AuditPlan` / `AuditProgramme`
- `DashboardController` -> logique de synthese directement en controller + metric globale dans Blade

4. Audit des migrations

4.1 Migrations manquantes

CRITICAL

? Pas de migration pour une table `mission\_services`, alors que `MissionService` la reference implicitement par convention Eloquent.

4.2 Migrations jamais executees

? Non determinable statiquement depuis le depot seul.

? Pour verifier proprement il faut comparer les fichiers de `database/migrations` avec la table runtime `migrations`.

4.3 Doublons et conflits

CRITICAL

? `2026\_03\_05\_153839\_add\_security\_fields\_to\_users\_table.php` ajoute `prenom` et `fonction`.

? `2026\_03\_05\_174934\_add\_user\_identity\_fields.php` re-ajoute `prenom` et `fonction` sans garde `Schema::hasColumn(...)`.

? Sur une installation propre, cela est un blocker potentiel.

CRITICAL

? `2026\_05\_09\_140000\_normalize\_mission\_workflow\_statuses.php` met a jour `missions.mission\_status` avant que cette colonne n'existe dans la chronologie des migrations.

MAJOR

? `2026\_05\_10\_100004\_add\_institutional\_fields\_to\_missions\_table.php` garde un default DB oriente legacy (`draft`) alors que le domaine applicatif travaille en `brouillon`.

MAJOR

? `2026\_05\_16\_100000\_phase2\_enrich\_services\_table.php` et

`2026\_05\_16\_100001\_phase2\_enrich\_entretiens\_table.php` utilisent des `if (!

Schema::hasColumn(...))` dans `up()` , mais leurs `down()` suppriment les colonnes de facon large. Une rollback peut retirer des colonnes preexistantes dans certains contextes.

4.4 Tables partiellement creees / derivees

MAJOR

? Les tables legacy des questionnaires coexistent avec les tables phase 1.5, sans couche d'abstraction forte ni plan clair de decommission.

MAJOR

? `questionnaire\_questions` est soft deletable, mais `questionnaire\_sections` ne l'est pas et peut hard-delete l'arbre.

4.5 Hardening migration recommande

1. Corriger l'ordre et/ou la garde de `normalize\_mission\_workflow\_statuses`.

2. Fusionner ou rendre idempotentes les migrations `users` qui doublonnent.
3. Fixer explicitement le default DB de `mission\_status`.
4. Normaliser les `down()` des migrations phase 2.

5. Audit des politiques

5.1 Models sans policy dediee

Models trouves sans policy explicite:

? `ActionCorrective`
? `Actif`
? `AuditLog`
? `Constat`
? `Controle`
? `EntretienResponse`
? `MissionRaciPreview`
? `MissionSwotPreview`
? `MissionTeamMember`
? `MissionWorkflowEvent`
? `Permission`
? `Processus`
? `Question`
? `Questionnaire`
? `QuestionnaireQuestion`
? `QuestionnaireSection`
? `RecommendationLibrary`
? `Reponse`
? `RiskLibrary`
? `Role`

Observation:

? tous n'ont pas necessairement besoin d'une policy dediee aujourd'hui;
? en revanche, pour des ressources avec ecriture directe, l'absence de policy devient un risque.

5.2 Politiques presentes mais non enregistrees

? Aucune policy trouvee dans `app/Politiques` n'apparait orpheline.
? Les 10 politiques presentes sont enregistrees dans `AppServiceProvider`.

5.3 Capacites incoherentes

CRITICAL

? `QuestionnaireTemplatePolicy` retourne `true` pour `view`, `create`, `update`, `delete`, `duplicate`.

? Cela contredit directement `User::canManageQuestionnaireLibrary()` et ouvre l'administration de la bibliotheque a tout utilisateur authentifie.

MAJOR

? `MissionDocumentPolicy` et `ServicePolicy` sont bien presentes, mais la qualite de la securisation reste partiellement affaiblie par les validations trop permissives des Form

Requests (`chef\_service\_user\_id`).

MINOR

? Plusieurs modeles d'ecriture continuent d'etre proteges seulement via les politiques du parent (`Mission`, `Entretien`, `Risque`) plutot que via leur propre policy.

6. Audit des vues Blade

6.1 Relations null dangereuses

MAJOR

? `resources/views/entretiens/index.blade.php` affiche l'action "Conduite" des qu'un `questionnaire\_template\_id` est present. Si le template a ete soft-delete ou inactiver, l'UI affiche encore un lien qui mene a un `404`.

6.2 Acces a colonnes inexistantes

? Aucun acces Blade critique a une colonne inexistante n'a ete confirme sur les vues phases 1.5 / 2.

6.3 Erreurs syntaxiques

? Aucune erreur syntaxique Blade evidente n'a ete confirmee dans les vues inspectees.

6.4 Encodage UTF-8 casse

MINOR

? `resources/views/services/index.blade.php` contient du texte corrompu:

- `Services audit•s`
- `p•rim•tre d•audit`
- `Cr•er le service`
- `Rapport service • bient•t`

? `routes/web.php` contient aussi des commentaires corrompus.

6.5 Vues stale / legacy

MINOR

? `resources/views/layouts/sidebar.blade.php` garde encore un lien legacy vers `module.questionnaires`, alors que la navigation principale moderne passe par `questionnaire-templates.\*`.

? Cela entretient le double systeme legacy / phase 1.5.

6.6 Dashboard data correctness

MAJOR

? `resources/views/dashboard.blade.php` execute directement `User::query()->where('active', true)->count()` dans la vue. Cela fuit un KPI global et melange presentation et data access.

MAJOR

? Le graphe "Repartition des risques par service" repose sur des donnees preparees incorrectement par le controller.

7. Normalisation recommandee

7.1 `status`

Standard recommande:

- ? toujours une colonne `status` pour l'etat principal d'une ressource.
- ? valeurs enumerees en constantes de modele.
- ? default DB et default modele obligatoirement alignes.

Exemples:

- ? `missions.status` (ou garder `mission\_status` mais figer la convention)
- ? `entretiens.status`
- ? `services.audit\_status`

7.2 `active`

Standard recommande:

- ? utiliser `active` BOOLEAN NOT NULL DEFAULT true` pour les ressources activables;
- ? pas de variantes `enabled`, `is\_active`, `visible` si non necessaire;
- ? documenter clairement si `active=false` masque l'entite ou interdit son usage.

7.3 `deleted\_at`

Standard recommande:

- ? utiliser `deleted\_at` uniquement si le modele utilise `SoftDeletes`;
- ? eviter les suppressions dures sur les parents quand les enfants sont soft deletables;
- ? privilegier l'archivage sur les referentiels (`questionnaire\_templates`, `questionnaire\_questions`, `services`, `mission\_documents`).

7.4 `validation\_status`

Standard recommande:

- ? reserver `validation\_status` aux workflows de validation humaine distincts du cycle de vie principal;
- ? valeurs conseillees: `pending`, `validated`, `rejected`, `returned`;
- ? ne pas l'utiliser a la place de `status`.

7.5 `metadata` JSON

Standard recommande:

- ? `metadata` uniquement pour les extensions non structurantes;
- ? ne pas stocker des champs metier majeurs dans `metadata`;
- ? documenter les cles admises par ressource;
- ? preferer des colonnes reelles pour:
 - statut
 - identifiants
 - proprietaires
 - niveaux de risque
 - dates de workflow

7.6 Conventions de nommage

Standard recommande:

- ? modeles singuliers: `MissionDocument`, `QuestionnaireTemplate`

? tables plurielles snake_case: `mission\_documents`, `questionnaire\_templates`
? FK en `\_id`
? routes ressources scopees par parent quand metierement necessaire:
- `missions/{mission}/services/{service}`
? eviter les alias de modele sans `\$table` explicite si l'on herite d'une table legacy:
- `MissionService` doit soit definir `protected \$table = 'services';`, soit disparaitre au profit de `Service`.

8. Classification des erreurs

CRITICAL

1. `MissionService` vise implicitement `mission\_services`, table inexistante.
2. Route binding `service` retourne `Service`, alors que les controllers phase 2 attendent `MissionService`.
3. `Mission` depend de `AuditPlan` / `AuditProgramme` sans modeles presents.
4. `QuestionnaireTemplatePolicy` ouvre la bibliotheque a tous les utilisateurs authentifies.
5. `ApiV1\RiskController::store()` bypass les contraintes de visibilite metier.
6. Migration `normalize\_mission\_workflow\_statuses` execute des updates avant existence confirmee de `mission\_status`.
7. Doublon de migrations `users` sur `prenom` / `fonction`.

MAJOR

1. `Reponse` mappe `observation` alors que la colonne reelle est `commentaire`.
2. `Permission::roles()->withTimestamps()` sans timestamps sur `permission\_role`.
3. `QuestionnaireSection` hard-delete des enfants `QuestionnaireQuestion` soft deletables et potentiellement references.
4. `EntretienConduiteController` duplique les `identified\_risks` sur sauvegardes progressives.
5. Dashboard: comptage des risques par service incorrect.
6. Dashboard Blade: KPI global `usersActive` calcule dans la vue.
7. `chef\_service\_user\_id` accepte n'importe quel `users.id` existant, sans contrainte de perimetre mission.
8. Default DB `missions.mission\_status` incoherent avec le domaine.
9. Plusieurs ressources d'ecriture n'ont pas de policy dediee (`Processus`, `Actif`, `Controle`, `ActionCorrective`).

MINOR

1. Mojibake / encodage casse dans `services/index` et certains commentaires.
2. Lien legacy `module.questionnaires` encore present.
3. `Entretien::questionnaireCompletionPercent()` peut surevaluer la progression.
4. `ActionCorrective` manque d'un cast date explicite.
5. `Questionnaire` legacy sous-modele par rapport a son schema.
6. Verification "migrations jamais executees" impossible statiquement sans base runtime.

9. Plan de correction priorise

Etape 1 - Remettre le schema et le bootstrap en etat de migration propre

1. Corriger `MissionService`:
 - soit ajouter `protected \$table = 'services';`
 - soit supprimer l'alias et revenir a `Service` partout.
2. Corriger `AppServiceProvider`:
 - binder `service` en retournant le meme type que celui attendu par les controllers;
 - idealement unifier sur `Service`.
3. Corriger les migrations `users` en doublon:
 - fusionner ou rendre idempotente `2026\_03\_05\_174934\_add\_user\_identity\_fields.php`.
4. Corriger `2026\_05\_09\_140000\_normalize\_mission\_workflow\_statuses.php`:
 - soit la deplacer apres l'ajout de `mission\_status`,
 - soit la garder par `Schema::hasColumn('missions', 'mission\_status')`.
5. Aligner le default DB de `missions.mission\_status` sur `brouillon`.

Etape 2 - Fermer les failles de securite

6. Reparer `QuestionnaireTemplatePolicy` pour reutiliser `User::canManageQuestionnaireLibrary()` et le scope departemental.
7. Restreindre `StoreRisqueRequest` / `Api\V1\RiskController::store()` avec une verification de visibilite réelle sur `actif\_id`.
8. Durcir `chef\_service\_user\_id`:
 - n'accepter que les utilisateurs éligibles a la mission ou du bon departement / perimetre.

Etape 3 - Stabiliser les workflows phase 1.5 / 2

9. Corriger la suppression des sections/questionnaires:
 - interdiction si reponses existantes, ou archivage uniquement.
10. Empotentiser la creation des `identified\_risks` en conduite:
 - `updateOrCreate()` ou deduplication par `entretien\_id + questionnaire\_question\_id + title`.
11. Corriger la resolution des templates soft-deletes dans les entretiens:
 - soit `withTrashed()` cote relation,
 - soit masquer l'action "Conduite" si template indisponible,
 - soit interdire le soft delete d'un template encore lie.

Etape 4 - Corriger la dette de coherence applicative

12. Corriger `Reponse` pour utiliser `commentaire`.
13. Ajouter timestamps au pivot `permission\_role` ou retirer `withTimestamps()`.
14. Ajouter les modeles manquants `AuditPlan` / `AuditProgramme` ou neutraliser la logique tant que non prete.
15. Ajouter les casts manquants (`ActionCorrective::date\_echeance`, autres dates legacy utiles).

Etape 5 - Corriger les couches presentation et pilotage

16. Corriger le dashboard:
 - comptage de risques reellement par service;
 - suppression du `User::query()` dans Blade;
 - toute la data doit venir du controller / service.
17. Corriger l'encodage des fichiers mojibake.
18. Nettoyer les liens legacy questionnaires si la bibliotheque phase 1.5 devient la seule source officielle.

Etape 6 - Hardening gouvernance et conventions

19. Ajouter des politiques dediees aux ressources d'ecriture encore non couvertes:

- `Processus`
- `Actif`
- `Controle`
- `ActionCorrective`

20. Normaliser tous les `status`, `active`, `deleted\_at`, `validation\_status`, `metadata`.

21. Documenter officiellement la coexistence ou la deprecation des tables legacy questionnaires.

Conclusion

Les phases 1.5 et 2 ont apporte une vraie valeur metier:

? questionnaires dynamiques

? entretiens structures

? services audites

? documents de mission

? consolidation

Mais elles ont aussi introduit plusieurs incoherences structurelles majeures, dont certaines sont des blockers de robustesse:

? alias `MissionService` non finalise

? policy questionnaires ouverte

? migrations `users` en doublon

? logique `Mission` referenceant des modeles absents

? creation API de risques insuffisamment protegee

Priorite absolue:

1. schema et migrations,

2. politiques et securite,

3. stabilisation des workflows phase 1.5 / 2,

4. nettoyage dashboard / vues / legacy.